

Chapter 1 Roadmap

Chapter Purpose

Chapter 1 establishes the governing argument for this book: that Active Directory security in federal, defense, intelligence, coalition, military, and mission-partner environments is not merely a Microsoft administration problem or a domain-hardening problem. It is an identity trust problem. This chapter introduces Active Directory as part of a broader federal identity trust system that includes directory services, credentialing, certificates, federation, cloud identity, authoritative attributes, privileged access, mission partners, governance requirements, and mission assurance obligations.

The chapter explains why defenders must learn to think like attackers without abandoning their defensive, engineering, assessment, authorization, and recovery responsibilities. It introduces the “Assume Breach” concept as the opening mindset for identity security engineering and frames the transition from a traditional cyber kill chain to an Active Directory identity attack lifecycle. The chapter also establishes the recurring analytical method used throughout this book: each major identity function is examined through its trust purpose, attack surface, adversary abuse pathways, observable evidence, containment and remediation requirements, validation methods used, governance consequences, and mission impact.

Chapter 1 serves as the conceptual foundation for Part I, the identity attack lifecycle in Part II, the defensive mirror in Part III, and the future-oriented discussion of identity-centric defense and warfare in Part IV.

Chapter Abstract

Active Directory was originally designed to centralize identity, authentication, authorization, and administrative control across an enterprise. In federal and military environments, those same capabilities concentrate agency and mission risk because control of the directory’s trusted core can quickly and easily become control over the agency’s ability to decide who or what should be trusted.

Chapter 1 establishes the book’s central thesis: the correct unit of analysis is not just the Active Directory domain, but the broader federal identity trust system in which the domain operates. That system includes directory

services, certificate services, federation services, Federal Public Key Infrastructure (FPKI), Personal Identity Verification (PIV) credentials, Common Access Cards (CAC), authoritative attributes, identity proofing, cloud identity, privileged access, mission partners, and the governance requirements that bind them.

This chapter introduces to the reader identity as a contested terrain, explains why attackers follow trust relationships rather than administrative diagrams, and presents assume breach as the starting point for identity security engineering. It also introduces the Active Directory identity attack lifecycle, the recurring attacker-and-defender analytical method, and the book's structure across foundations, offense, defense, recovery, governance, and future identity-centric defense and warfare.

Key Terminology

Active Directory

Active Directory Domain Services (AD DS)

Identity Trust System

Federal Identity, Credential, and Access Management (FICAM)

Department of Defense Identity, Credential, and Access Management (DoD ICAM)

Identity Plane

Trust Boundary

Tier 0

Privileged Access

Assume Breach

Cyber Kill Chain

Identity Kill Chain

Attack Pathway

Mission Assurance

Risk Management Framework (RMF)

Zero Trust

Learning Objectives

- Explain Why Active Directory Security Is a Mission Problem, Not a Domain Problem
- Describe the Identity Trust System as the Book's Primary Unit of Analysis
- Distinguish Between Administrative Structure and Adversary Control Pathways
- Explain Why Attackers Follow Trust Relationships Instead of Organizational Charts
- Describe How FICAM and DoD ICAM Change the Meaning of Active Directory Security
- Explain How Assume Breach Applies to Identity Security Engineering
- Relate the Traditional Cyber Kill Chain to an Active Directory Identity Attack Lifecycle
- Identify Why Identity Security Findings Must Translate Into Mission Risk, RMF Evidence, and Control Validation

Standards, Frameworks, and Guidance Covered

- Federal Identity, Credential, and Access Management as the Federal Identity Architecture Lens
- Department of Defense Identity, Credential, and Access Management as the Defense Identity Implementation Lens
- Risk Management Framework as the Authorization and Control-Validation Model
- Federal Information Security Modernization Act (FISMA) as the Federal Security Governance Foundation
- NIST Special Publications as the Primary Federal Cybersecurity and Digital Identity Guidance Layer
- Federal Information Processing Standards (FIPS) as the Federal Identity and Security Baseline Layer
- Office of Management and Budget (OMB) Identity and Zero Trust Memoranda as Federal Direction
- Cybersecurity and Infrastructure Security Agency (CISA) Zero Trust Guidance as Federal Maturity Guidance

- Defense Information Systems Agency (DISA) STIGs and SRGs as Technical Configuration and Hardening Authorities
- MITRE ATT&CK Framework as the Adversary-Behavior Mapping Framework
- MITRE D3FEND Framework as a Defensive Countermeasure Mapping Reference

Main Chapter 1 Body

- **1.1 Reading Active Directory as a Trust System**
 - 1.1.1 Active Directory as More Than a Directory Service
 - 1.1.2 The Difference Between a Domain and an Identity Trust System
 - 1.1.3 Why the Domain Is a Real Security Boundary, But Not The Only Security Boundary
 - 1.1.4 How Trust Extends Through Forests, Domains, Certificates, Federation, Cloud Identity, and Mission Partners
 - 1.1.5 Why Identity Trust Becomes Mission Infrastructure in Federal and Military Defense Environments
 - 1.1.6 Why Identity Failure Becomes Mission Risk
- **1.2 Why Active Directory Remains Central to Federal and Military Environments**
 - 1.2.1 Active Directory as the Operational Mainstay of Enterprise Identity
 - 1.2.3 Active Directory as the Control Plane for Users, Computers, Groups, Services, and Policy
 - 1.2.4 Active Directory's Role in Privileged Access and Administrative Authority
 - 1.2.5 Active Directory's Role in Hybrid Identity and Cloud Trust
 - 1.2.6 Active Directory's Role in Mission Partner and Cross-Boundary Access
 - 1.2.7 Why Legacy Domains Remain Operationally Critical
- **1.3 The Federal Identity Trust Problem**
 - 1.3.1 Why Federal Identity Is Not Only a Microsoft Architecture Problem
 - 1.3.2 FICAM as the Government-Wide Identity Architecture Lens
 - 1.3.3 DoD ICAM as the Department-Level Identity Implementation Lens
 - 1.3.4 How Identity Governance Connects People, Devices, Services, Attributes, Credentials, and Access

- 1.3.5 Person Entities and Non-Person Entities (NPEs) as Federal Identity Subjects
- 1.3.6 Authoritative Attributes and the Problem of Trusting Identity Data and information
- 1.3.7 Credential issuance, Credential Binding, and Access Authorization as a Trust Chain
- 1.3.8 Why Identity Governance Must Be Tested Against Real Attack Pathways

- **1.4 Identity as the Battlefield**
 - 1.4.1 Why Modern Adversaries Target Identity Before Systems
 - 1.4.2 Why Credentials, Tokens, Certificates, and Sessions Are Operational Access
 - 1.4.3 Why Administrative Rights Are Often Less Important Than Control Pathways
 - 1.4.4 Why Attackers Prefer Trust Abuse Over Exploitative Noise
 - 1.4.5 Why Identity Attacks Often Appear as Normal Authentication Activities
 - 1.4.6 Why Defenders Must Protect Trust Decisions, Not Only Endpoints
 - 1.4.7 Identity as Contested Terrain in Federal and Military Environments

- **1.5 How to Think Like an Attacker Without Abandoning the Defender's Mission**
 - 1.5.1 Attacker Thinking as a Defensive Skill Set
 - 1.5.2 How Attackers Read and Blueprint a Targeted Environment
 - 1.5.3 Why Attackers Ask "What Can This Identity Control, Access, Modify, or Impersonate?"
 - 1.5.3.1 Access Versus Control
 - 1.5.3.2 Read, Write, Reset, Enroll, Replicate, Delegate, and Impersonate Rights
 - 1.5.3.3 Why Low-Privilege Identities Can Still Create High-Impact Pathways
 - 1.5.3.4 Why Attackers Value Downstream Authority More Than Job Titles
 - 1.5.3.5 How Small Rights Become Control Pathways
 - 1.5.3.6 How Defenders Translate Identity Control Into Mission Risk
 - 1.5.4 Why Attackers Scout for Attack Pathways and Not Just Vulnerabilities
 - 1.5.5 Why Attackers Chain Weaknesses Across Identity Systems
 - 1.5.6 How Defenders Use Attacker Thinking to Validate Controls

- 1.5.7 The Ethical and Authorized Boundary of Offensive Thinking
- 1.5.8 Why Federal Defenders Must Translate Attack Pathways Into Mission Risk

- **1.6 Assume Breach as the Starting Point for Identity Security Engineering**

- 1.6.1 What It Means to Assume Breach
- 1.6.2 What Assume Breach Does Not Mean
- 1.6.3 Why Preventive Controls Alone Are Not Enough
- 1.6.4 Why Identity Security Must Be Validated After Initial Access Is Assumed
- 1.6.5 How Assume Breach Changes Active Directory Assessments
- 1.6.6 How Assume Breach Changes Logging and Detection Requirements
- 1.6.7 How Assume Breach Changes Recovery and Restoration Planning
- 1.6.8 Assume Breach and Mission Assurance

- **1.7 From Cyber Kill Chain to Identity Kill Chain**

- 1.7.1 Why Traditional Kill Chain Models Need Identity-Specific Translation
- 1.7.2 Reconnaissance as Identity Exposure Discovery
- 1.7.3 Enumeration as Trust Relationship Discovery
- 1.7.4 Initial Identity Acquisition as the First Trust Break
- 1.7.5 Credential Acquisition as Access Material Collection
- 1.7.6 Identity Authority Expansion as Privilege Growth
- 1.7.7 Enterprise Identity Mobility as Movement Through Established Trust Chains
- 1.7.8 Persistence as Long-Term Control of Identity Infrastructure
- 1.7.9 Domain Dominance as Strategic Trust Collapse
- 1.7.10 Why the Identity Kill Chain Structures Part II

- **1.8 The Active Directory Attack Lifecycle Used In This Book**

- 1.8.1 **Stage 1** - Passive Reconnaissance
- 1.8.2 **Stage 2** - Active Enumeration
- 1.8.3 **Stage 3** - Initial Identity Acquisition
- 1.8.4 **Stage 4** - Credential Acquisition
- 1.8.5 **Stage 5** - Identity Authority Expansion
- 1.8.6 **Stage 6** - Enterprise Identity Mobility
- 1.8.7 **Stage 7** - Persistence and Domain Dominance

- 1.8.8 Why the Lifecycle Is Not Linear in Real-World Intrusions
- 1.8.9 How Defensive Security Engineering Mirrors the Attack Lifecycle

▪ **1.9 The Defender's Problem: Seeing What The Attacker Sees**

- 1.9.1 Why Administrative Visibility Is Not the Same as Attack-Path Visibility
- 1.9.2 Why Inventory Does Not Equal Total Visibility and Control
- 1.9.3 Why Compliance Does Not Automatically Equal Security
- 1.9.4 Why Logging Does Not Automatically Equal Detection
- 1.9.5 Why Hardening Does Not Automatically Equal Resilience
- 1.9.6 Why Recovery Plans Must Assume Identity Trust May Be Corrupted
- 1.9.7 Why Defenders Need Security Engineering, Detection, Governance, and Recovery Together

▪ **1.10 Federal Mission Risk and the Identity Control Plane**

- 1.10.1 Identity Compromise as a Mission-Impact Event
- 1.10.2 Privileged Access as Operational Authority
- 1.10.3 Federation Trust as Mission Partner Dependency
- 1.10.4 Cloud Identity as an Extension of Enterprise Trust
- 1.10.5 Certificate Trust as Cryptographic Authority
- 1.10.6 Group Policy as Enterprise Configuration Authority
- 1.10.7 Directory Data as Authoritative Identity Memory
- 1.10.8 Why Identity Risk Must Be Expressed in Mission Terms

▪ **1.11 Governance, Authorization, and Evidence in Identity Security**

- 1.11.1 Why Federal Identity Security Must Produce Evidence
- 1.11.2 Risk Management Framework (RMF) as the Control-Validation Structure
- 1.11.3 FISMA as the Federal Security Accountability Foundation
- 1.11.4 STIGs and SRGs as Technical Configuration Evidence
- 1.11.5 Information Assurance Vulnerability Alert (IAVA) as Operational Vulnerability-Response Drivers
- 1.11.6 eMASS as the Authorization Evidence Repository
- 1.11.7 Plans of Action & Mitigation (POA&M) as the Risk-Tracking Accountability and Remediation Mechanism
- 1.11.8 Continuous Monitoring as Identity Security Sustainment

- 1.11.9 Why Governance Must Be Informed by Attack Pathways

- **1.12 The Book's Operating Model**

- 1.12.1 Architecture Before Attack
- 1.12.2 Protocols Before Exploitation
- 1.12.3 Identity Governance Before Authorization Claims
- 1.12.4 Assessment Before Offensive Validation
- 1.12.5 Offensive Tradecraft Before Defensive Engineering
- 1.12.6 Detection Before Response
- 1.12.7 Recovery Before Trust Restoration
- 1.12.8 Future Warfare After Current-State Engineering

- **1.13 How This Book Is Organized**

- 1.13.1 **Part I** - Foundations and Terrain
- 1.13.2 **Part II** - The Active Directory Identity Attack Lifecycle
- 1.13.3 **Part III** - Defense, Detection, Recovery, and Governance
- 1.13.4 **Part IV** - Operational Lessons and the Future of Identity-Centric Defense and Warfare
- 1.13.5 How Chapter-Level MITRE ATT&CK Framework Mappings Will Be Used and Applied
- 1.13.6 How Chapter-Level Standards and Guidance Sections Will Be Used and Applied
- 1.13.7 How Offensive and Defensive Concepts Will Be Paired
- 1.13.8 How Attacker and Defender Perspectives Will Be Used and Applied

- **1.14 What This Book Is About and What It Is Not**

- 1.14.1 This Book Is an Identity Security Engineering Reference
- 1.14.2 This Book Is an Offensive and Defensive Active Directory Security Guide
- 1.14.3 This Book Is a Federal and Military Identity Trust Analysis Handbook
- 1.14.4 This Book Is Not Another Active Directory Administration Manual
- 1.14.5 This Book Is Not Another Active Directory Penetration Testing Playbook
- 1.14.6 This Book Is Not Another Active Directory Security Compliance Checklist
- 1.14.7 Why Those Boundaries and Distinctions Matter

- **1.15 Summary and Transition**
 - 1.15.1 Key Concepts Reviewed
 - 1.15.2 Active Directory as Identity Trust Infrastructure
 - 1.15.3 Identity as the Battlefield
 - 1.15.4 Assume Breach as an Engineering Model
 - 1.15.5 From Cyber Kill Chain to Identity Kill Chain
 - 1.15.6 Federal Governance as a Security Requirement
 - 1.15.7 Why Chapter 2 Moves Into Architecture of Authority

Included Figures

- Figure 1-1. Active Directory As Part of the Federal Identity Trust System
- Figure 1-2. Domain Boundary Versus Identity Trust System Boundary
- Figure 1-3. Administrative View Versus Attacker Control-Path View
- Figure 1-4. From Cyber Kill Chain to Identity Kill Chain
- Figure 1-5. Identity Trust Failure as Mission Risk
- Figure 1-6. Book Structure: Architecture, Offense, Defense, Recovery, and Warfare

Included Tables

- Table 1-1. Active Directory Component Roles in the Overall Identity Trust System
- Table 1-2. Domain-Centric View Versus Identity Trust Systems View
- Table 1-3. Attacker Questions Versus Defender Questions
- Table 1-4. Traditional Cyber Kill Chain Versus Active Directory Identity Kill Chain
- Table 1-5. Identity Security Findings and Federal Evidence Outputs
- Table 1-6. Book Parts and the Operational Purpose They Serve to Provide

Included Case Studies

- Case Study 1-1. When a Domain Compromise Becomes a Mission Trust Failure
- Case Study 1-2. When Compliance Evidence Failed to Reveal an Attack Pathway
- Case Study 1-3. When Federation Extended the Blast Radius Beyond the Domain

Included Labs / Exercises

- Exercise 1-1. Draw the Identity Trust System Around a Domain
- Exercise 1-2. Translate an Administrative Diagram Into an Attacker Control-Pathway Diagram
- Exercise 1-3. Build an Assume-Breach Question Set for an Active Directory Environment
- Exercise 1-4. Map a Simple Identity Attack Pathway to Mission Risk
- Exercise 1-5. Identify Which Evidence Would Support an RMF Identity Finding

Offensive Concepts Covered

1.11.1 Attacker Mindset

1.11.2 Attack-Path-Like Thinking

1.11.3 Assume Breach Reasoning

1.11.4 Identity Kill Chain

1.11.5 Trust Relationship Abuse

1.11.6 Control Pathway Discovery

1.11.7 Identity-Centric Reconnaissance

1.11.8 Mission-Impact Targeting

Defensive Concepts Covered

1.12.1 Identity Security Engineering

1.12.2 Mission and Information Assurance

1.12.3 Tier 0-Like Thinking

1.12.4 Trust Boundary Identification

1.12.5 Control Validation

1.12.6 Continuous Monitoring

1.12.7 Authorization Evidence and Artifacts

1.12.8 Recovery-Oriented Identity Defense

Offensive Tools and Tradecraft Discussed

- 1.13.1 No Offensive Tools Used as Primary Instruction in Chapter 1
- 1.13.2 Tool Categories Introduced Conceptually for Subsequent Chapters
 - 1.13.2.1 Reconnaissance Tools
 - 1.13.2.2 Enumeration Tools
 - 1.13.2.3 Graph-Based Attack Pathway Tools
 - 1.13.2.4 Credential Access Tools
 - 1.13.2.5 Ticket and Token Analysis Tools

Defensive Tools and Tradecraft Discussed

- 1.14.1 eMASS as Authorization Evidence and Artifacts Repository
- 1.14.2 SIEM Platforms as Identity Telemetry Aggregators
- 1.14.3 Microsoft Defender for Identity (MDI) as Identity Threat Detection
- 1.14.4 Microsoft Sentinel as Cloud-Native Security Analytics
- 1.14.5 STIG and SRG Validation Tooling
- 1.14.6 Vulnerability and Configuration Assessment Tooling
- 1.14.7 Identity Governance and Administration Tooling

Primary FICAM Components Covered

- 1.15.1 Identity
- 1.15.2 Credential
- 1.15.3 Access Management
- 1.15.4 Federation
- 1.15.5 Assurance
- 1.15.6 Attribute Governance
- 1.15.7 Person Entity Identity

1.15.8 Non-Person Entity (NPE) Identity

1.15.9 Mission Partner Trust

MITRE ATT&CK Framework Coverage

1.16.1 MITRE ATT&CK Introduced as the Adversary-Behavior Mapping Layer

1.16.2 Reconnaissance as the Beginning of Identity Exposure Discovery

1.16.3 Discovery as the Mapping of Identity Objects and Trust Relationships

1.16.4 Credential Access as the Abuse of Authentication Material

1.16.5 Privilege Escalation as Expansion of Identity Authority

1.16.6 Lateral Movement as Mobility Through Trust

1.16.7 Persistence as Long-Term Control of Identity Infrastructure

1.16.8 Defense Evasion as the Concealment of Identity Abuse

1.16.9 Impact as Mission Consequence of Identity Compromise

Lessons Learned and Key Takeaways

1.18.1 Active Directory Security Is Identity Trust Security

1.18.2 The Domain Is Necessary But Not Sufficient as the Primary Unit of Analysis

1.18.3 Attackers Follow Trust Relationships

1.18.4 Assume Breach Changes How Identity Systems Are Assessed

1.18.5 Federal Identity Security Must Produce Evidence and Artifacts

1.18.6 Governance Without Attack-Pathway Awareness Is Incomplete Governance Security

1.18.7 Defense Must Mirror the Identity Attack Lifecycle

Recommended Reading

1.19.1 Federal Identity, Credential, and Access Management Guidance

1.19.2 Department of Defense Identity, Credential, and Access Management Guidance

1.19.3 Risk Management Framework Guidance

1.19.4 NIST Digital Identity Guidance

1.19.5 Zero Trust Guidance

1.19.6 MITRE ATT&CK Framework

1.19.7 MITRE D3FEND Framework

1.19.8 Active Directory Security References

Introduction to Chapter 2 Transitional Paragraph

Chapter 2 moves from the idea of the identity trust system into the architecture that gives it shape. It examines forests, domains, trusts, schema, Organizational Units (OUs), domain controllers, and administrative boundaries as structures of authority. Where Chapter 1 explains why identity trust matters, Chapter 2 explains how Active Directory organizes that trust.